



Instituto Politécnico Nacional
Escuela Superior de Cómputo
Ingeniería en Sistemas Computacionales



Gobierno de TI

Servicio evaluado: Servicio Integral de Seguridad de Aplicaciones

Alumnos:

Carol Monserrat Chávez Hernández

Alfredo Bautista Ríos

Diego Alejandro Moreno Martínez

Grupo: 7CV2

Profesora: Palacios Solano Rocío

Fecha de entrega: 05/01/2026

1. Introducción	4
2. Objetivo del servicio de TI	5
3. Descripción del servicio	5
4. Misión, visión y valores de la empresa	5
4.1 Misión	5
4.2 Visión.....	5
4.3 Valores	5
5. Metas corporativas (COBIT) y Balanced Scorecard	6
6. Metas de TI (COBIT)	6
7. Cascada de metas (mapeo y relaciones primarias/secundarias)	7
8. Mapa estratégico (COBIT + BSC).....	9
9. Caso de Negocio (Formato)	10
9.1 Información general.....	10
9.2 Antecedentes.....	10
9.3 Justificación técnica del servicio	10
9.4 Alcance	10
9.5 Objetivo.....	11
9.6 Riesgos clave	11
9.7 Definición de indicadores	11
9.8 Beneficios esperados	12
9.9 Planeación de alto nivel	12
9.10 Dependencias con otros proyectos	12
9.11 Personal involucrado	13
9.12 Justificación económica del proyecto de TI	13
9.12.1 Estudio de mercado	13
9.12.2 Costos de mantenimiento	13
9.12.3 Costos de operación	13
9.12.4 Procedimientos de adquisición	13
10. Cédula de Servicio (ITIL).....	14
10.1 Información general del servicio	14
10.2 Responsables del servicio (Matriz RACI).....	15
10.3 Roles y puntos de contacto	16

10.4 Condiciones generales / requisitos para proporcionar el servicio	16
10.5 Identificación de componentes de infraestructura	17
10.6 Niveles de servicio (SLA - acuerdos de servicios para los usuarios)	18
10.7 Niveles de servicio (OLA-acuerdos de servicios respecto a elementos de configuración de infraestructura, aplicaciones, etc.)	18
11. Inventario de Activos	20
12. Matriz de Riesgos (ISO 27000) (Matriz CID, matriz de infraestructuras críticas)	21
12.1 Infraestructuras críticas	21
13. BIA Táctico	22
13.1 BIA Táctico 1: Evaluación de seguridad de aplicaciones	22
13.2 BIA Táctico 2: Gestión de vulnerabilidades y hardening	22
13.3 BIA Táctico 3: Monitoreo y respuesta a incidentes	23
14. BIA Operacional	23
15. Plan de Continuidad.....	23
15.1 Activación y gobernanza	23
15.2 Estrategias por escenario	24
15.3 Respaldo, restauración y pruebas	24
16. Anexos.....	24
16.1 Glosario	24

1. Introducción

El gobierno de TI proporciona el marco para dirigir y controlar las capacidades tecnológicas de una organización, asegurando que la inversión en tecnología genere valor, reduzca riesgos y opere con niveles de servicio acordes al negocio. En el contexto actual, el riesgo cibernético se ha consolidado como un factor de continuidad operativa y de cumplimiento: una falla de seguridad no solo impacta la disponibilidad de plataformas, también compromete la confidencialidad e integridad de la información, genera costos de remediación y puede deteriorar la confianza de usuarios y partes interesadas. Además, el crecimiento de arquitecturas distribuidas, servicios expuestos a internet, integraciones con terceros y ciclos de entrega cada vez más cortos incrementa la superficie de ataque y hace más probable que un incidente tenga efectos transversales. Bajo estas condiciones, el reto no es únicamente “tener seguridad”, sino gobernarla: definir responsabilidades, priorizar inversiones, establecer métricas verificables y asegurar que los controles se ejecuten de forma consistente a lo largo del ciclo de vida del software.

Este documento desarrolla el proyecto final a partir del diseño de un servicio de TI orientado a la seguridad de aplicaciones. El servicio integra prácticas de AppSec y DevSecOps, pruebas automatizadas (SAST/DAST), auditorías y pruebas de penetración controladas, así como monitoreo y respuesta a incidentes para proteger aplicaciones críticas. Su planteamiento asume que la seguridad debe incorporarse desde el diseño y la construcción, no solo al final como una revisión puntual, y que la operación diaria requiere disciplina para mantener configuraciones, dependencias y entornos bajo control. En términos prácticos, el servicio propone mecanismos para detectar defectos y vulnerabilidades de manera temprana, reducir el tiempo de exposición, estandarizar la evidencia de cumplimiento y habilitar una respuesta coordinada ante eventos de seguridad. De esta forma, el servicio no se limita a herramientas: se define como un conjunto de capacidades, procesos, roles y acuerdos operativos que permiten sostener la seguridad como parte del desempeño normal de TI.

El propósito del proyecto no es únicamente describir el servicio, sino alinearlos con objetivos corporativos mediante COBIT y el enfoque del Balanced Scorecard, formalizar compromisos operativos con ITIL a través de una Cédula de Servicio y establecer un esquema de gestión de riesgos basado en ISO 27000. COBIT se utiliza para vincular necesidades del negocio con metas de TI y para construir una cascada de objetivos que haga trazable la contribución del servicio. El Balanced Scorecard permite expresar esa contribución en términos equilibrados: resultados financieros y de valor, satisfacción del cliente/usuario, desempeño de procesos internos y capacidades de aprendizaje y crecimiento. En paralelo, ITIL aporta el lenguaje operativo para establecer alcances, entradas y salidas del servicio, niveles de servicio, roles y responsabilidades (incluyendo RACI), además de los compromisos medibles que habilitan el seguimiento. Finalmente, ISO 27000 proporciona la base para analizar y tratar riesgos desde la perspectiva de la triada CID (confidencialidad, integridad y disponibilidad), complementando el análisis con infraestructuras críticas y dependencias relevantes.

2. Objetivo del servicio de TI

Asegurar la confidencialidad, la integridad y el acceso a los aplicativos de la organización, reduciendo el área de ataque a través de una arquitectura segura y la identificación anticipada de errores de seguridad.

3. Descripción del servicio

El servicio proporciona una arquitectura de red robusta, creada para resguardar y administrar los bienes digitales de la organización a través de la aplicación de controles perimetrales avanzados. El propósito principal es garantizar la integridad de la infraestructura tecnológica, estableciendo barreras defensivas que protejan los datos críticos ante amenazas externas e internas. El servicio abarca el ciclo de vida de seguridad de forma exhaustiva, cubriendo desde la fase de diseño de la topología de red segura hasta la realización de pruebas de penetración previas a las fases productivas. Además, incluye la realización de auditorías periódicas a las aplicaciones web y móviles para detectar debilidades y reducir los riesgos de manera proactiva.

4. Misión, visión y valores de la empresa

4.1 Misión

Ser el socio tecnológico estratégico de nuestros clientes, impulsando su crecimiento y eficiencia a través de soluciones de TI innovadoras, seguras y a la medida. Nos comprometemos a entender a fondo sus necesidades para ofrecer servicios de consultoría, desarrollo de software, gestión de infraestructura y soporte técnico con los más altos estándares de calidad y un enfoque proactivo.

4.2 Visión

Consolidarnos como la empresa líder en servicios de TI en la región, siendo reconocidos por nuestra excelencia operativa, nuestra capacidad de adaptación a las nuevas tecnologías y por construir relaciones a largo plazo basadas en la confianza y la generación de valor tangible para nuestros clientes y colaboradores.

4.3 Valores

- **Innovación constante:** Abrazamos el cambio y buscamos continuamente nuevas y mejores formas de aplicar la tecnología para resolver los desafíos de negocio de nuestros clientes.
- **Compromiso con el cliente:** La satisfacción y el éxito de nuestros clientes son el centro de todas nuestras operaciones. Escuchamos activamente sus necesidades y superamos sus expectativas.
- **Integridad y transparencia:** Actuamos con honestidad, ética y transparencia en todas nuestras interacciones. Construimos confianza a través de una comunicación clara y directa.
- **Trabajo en equipo y colaboración:** Fomentamos un ambiente de colaboración donde se valora el conocimiento colectivo y se promueve el apoyo mutuo para alcanzar objetivos comunes.
- **Calidad y excelencia:** Nos esforzamos por la excelencia en todo lo que hacemos, desde el desarrollo de un proyecto hasta la atención en un ticket de soporte, garantizando resultados de alta calidad.
- **Desarrollo del talento:** Invertimos en el crecimiento profesional y personal de nuestros colaboradores, reconociendo que su talento es el pilar fundamental de nuestro éxito.

5. Metas corporativas (COBIT) y Balanced Scorecard

Las metas corporativas se establecen con el enfoque de COBIT para asegurar alineación entre TI y negocio, priorizando la entrega de valor, la optimización del riesgo y el uso eficiente de recursos. Se presentan bajo Balanced Scorecard para mantener equilibrio entre perspectivas.

Dimensión BSC	Meta corporativa	Indicador sugerido	Meta (referencia)
Financiera	Reducir el costo total de incidentes de seguridad y remediación asociados a aplicaciones críticas.	Costo anual por incidentes (MXN) / Número de incidentes severos	Disminución $\geq$ 20% anual
Cliente/Usuario	Incrementar la confianza de usuarios internos y dueños de aplicaciones mediante mayor estabilidad y seguridad percibida.	Satisfacción del usuario (encuesta) / Cumplimiento de SLA	$\geq$ 90% satisfacción; $\geq$ 95% SLA
Procesos internos	Estandarizar el ciclo de liberación segura, disminuyendo vulnerabilidades críticas antes de producción.	% de releases con controles AppSec completos	$\geq$ 95% releases evaluados
Aprendizaje y crecimiento	Fortalecer competencias y cultura DevSecOps en equipos técnicos y de producto.	% del personal clave certificado/capacitado; # sesiones	$\geq$ 80% personal clave capacitado

6. Metas de TI (COBIT)

Las metas de TI traducen las metas corporativas a resultados específicos del área tecnológica. En este servicio, se enfocan en seguridad por diseño, operación confiable, remediación trazable y desarrollo de capacidades.

Dimensión BSC	Meta de TI	Indicador sugerido	Meta (referencia)
Financiera	Optimizar el uso de licencias y plataformas SAST/DAST, evitando duplicidades y maximizando cobertura.	Cobertura de escaneo por costo / Aprovechamiento de licencias	$\geq$ 90% uso efectivo
Cliente/Usuario	Asegurar tiempos de atención y comunicación claros para hallazgos e	Tiempo de respuesta inicial (TTR) / Tiempo de remediación (TTRem)	TTR $\leq$ 2 h (crítico); TTRem $\leq$ 15 días (alto)

	incidentes.		
Procesos internos	Integrar controles automáticos en CI/CD y establecer un flujo de gestión de vulnerabilidades trazable.	% hallazgos con ticket y responsable / Lead time de remediación	>= 98% trazabilidad
Aprendizaje y crecimiento	Desarrollar habilidades de AppSec, pentesting y operación de seguridad (Blue Team) en el equipo.	Horas de capacitación trimestral / Evaluaciones técnicas	>= 12 h por trimestre por rol

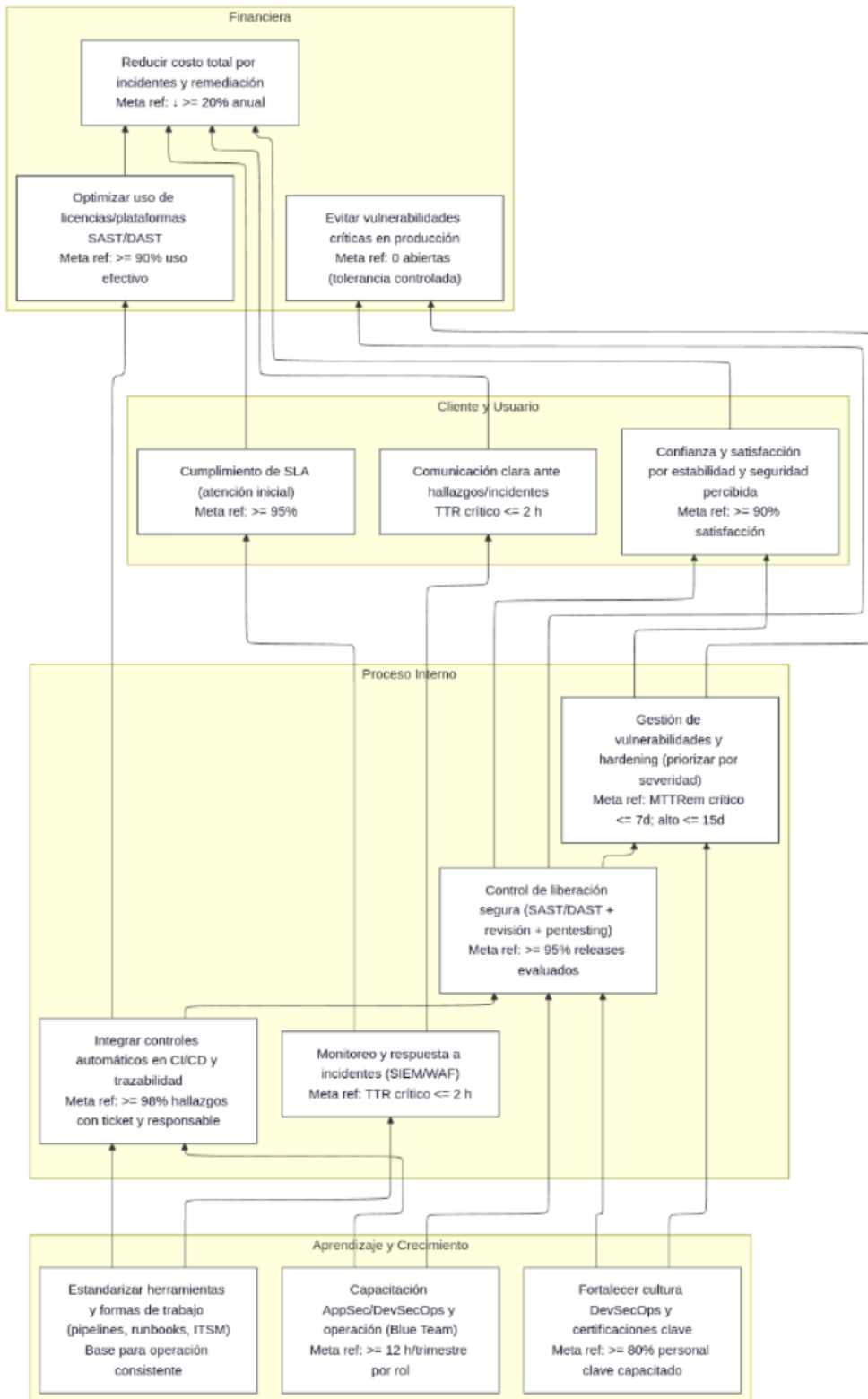
7. Cascada de metas (mapeo y relaciones primarias/secundarias)

La cascada de metas define la relación entre las metas corporativas y las metas de TI. Se marca como primaria la contribución directa al objetivo corporativo y como secundaria la contribución de soporte.

Objetivo de gobierno	Meta corporativa	Meta de TI (primaria)	Meta de TI (secundaria)	Evidencia / resultado esperado (medible)
Optimizar beneficios	Aumentar confianza y continuidad del servicio (menos fallas por seguridad y menos impacto reputacional)	Implementar gates de seguridad en CI/CD (SAST/DAST/SCA) como criterio de liberación	Tablero ejecutivo de postura AppSec (tendencias, hallazgos, remediación, cumplimiento)	Más releases “sin hallazgos críticos”, menos retrabajo y mejor cumplimiento de compromisos; reportes periódicos para dirección
Optimizar riesgos	Reducir probabilidad e impacto de incidentes (CID) en aplicaciones críticas	Operar un ciclo formal de gestión de vulnerabilidades + priorización por criticidad (CVSS/impacto negocio)	Fortalecer detección y respuesta (SIEM/WAF, playbooks, escalamiento)	Disminución de incidentes severos, menor MTTR, evidencias de tratamiento de riesgos (registro, aprobación, seguimiento)
Optimizar	Reducir costo total de	Automatizar	Optimizar	Menos horas

recursos	remediación y uso ineficiente de herramientas/persona s	pruebas y evidencias (SAST/DAST/SCA) y estandarizar el flujo (pipelines, plantillas)	licenciamiento/plataforma s y capacidad del equipo (entrenamiento, roles claros)	manuales por auditoría/prueba , mejor uso de licencias, mayor cobertura con el mismo equipo
----------	--	--	---	--

8. Mapa estratégico (COBIT + BSC)



9. Caso de Negocio (Formato)

9.1 Información general

Campo	Valor
Nombre del servicio / proyecto	Servicio Integral de Seguridad de Aplicaciones
Clave	SEG-APP-001
Fecha propuesta de inicio	25 de agosto de 2025
Fecha propuesta de fin	7 de enero de 2026
Administrador(es) del proyecto	Carol Monserrat Chávez Hernández; Diego Alejandro Moreno Martínez; Alfredo Bautista Ríos

9.2 Antecedentes

Las aplicaciones web de cualquier organización gubernamental manejan información crítica y de alto valor del tipo institucional, académica, personal, privada, etc. Actualmente, estas aplicaciones están expuestas a amenazas cibernéticas avanzadas que evolucionan constantemente. En el último año, se han identificado intentos de explotación de vulnerabilidades en aplicaciones web, y distintas plataformas, incluyendo amenazas como inyecciones SQL, exposición de datos a través de APIs no protegidas, ataques del tipo Man in the Middle y cross-site scripting (XSS). La falta de un servicio especializado de seguridad de aplicaciones incrementa el riesgo de brechas de seguridad, pérdida y filtrado de datos sensibles e interrupciones operativas.

Derivado de situaciones de la misma índole que afectan a la confianza de todos los usuarios de los que su información está involucrada, surge este proyecto con el propósito de desarrollar y establecer una base de sistema de protección a todas las aplicaciones críticas del sistema institucional.

Esta solución ofrece seguridad inmediata para las vulnerabilidades existentes en el código sin necesidad de modificarlo, lo cual da tiempo al equipo de desarrollo para aplicar correcciones de fondo de manera planificada y segura.

Además de una constante actualización en la búsqueda y oportuna protección de nuevas amenazas.

9.3 Justificación técnica del servicio

El Servicio Integral de Seguridad de Aplicaciones implementa controles técnicos avanzados para proteger las aplicaciones en todas las capas. Incluye análisis estático y dinámico de código (SAST/DAST), gestión de vulnerabilidades, y monitoreo continuo. Este servicio permite identificar y remediar vulnerabilidades antes de que sean explotadas, asegurando el cumplimiento de estándares de seguridad y reduciendo la superficie de ataque. La integración con el ciclo de vida de desarrollo (DevSecOps) garantiza que la seguridad sea un componente fundamental desde el diseño.

9.4 Alcance

El proyecto abarca la implementación de un servicio de seguridad para las aplicaciones críticas de la organización, incluyendo:

- Análisis del código fuente y pruebas de penetración.
- Configuración de políticas de seguridad y gestión de vulnerabilidades.
- Monitoreo continuo y respuesta a incidentes.

- Capacitación al personal en buenas prácticas de seguridad.
- Generación de reportes mensuales de estado de seguridad.

9.5 Objetivo

Reducir en un 95 % las vulnerabilidades críticas y altas en las aplicaciones protegidas, y asegurar una detección y respuesta a incidentes en un tiempo no mayor a 2 horas, dentro de los 60 días posteriores a la implementación.

9.6 Riesgos clave

Descripción del Riesgo	Impacto	Probabilidad
Falsos positivos en la detección de vulnerabilidades.	Medio	Media
Resistencia al cambio por parte de los equipos de desarrollo	Medio	Alta
Incremento inicial en el tiempo de desarrollo por integración de controles.	Bajo	Media
Dependencia de terceros en la adquisición de licencias de seguridad	Medio	Media
Mala integración con sistemas heredados expuestos a posibles fugas de información	Alto	Media

9.7 Definición de indicadores

Indicador	Tipo	Fórmula/definición	Frecuencia	Meta
Cumplimiento de SLA de atención inicial	Operativo	Solicitudes atendidas dentro de SLA / Total de solicitudes	Mensual	$\geq 95\%$
Tiempo medio de remediación (MTTRem) por severidad	Operativo	Promedio de días desde hallazgo a cierre (alto/crítico)	Mensual	Crítico ≤ 7 días; Alto ≤ 15 días
Vulnerabilidades críticas en producción	Riesgo	Conteo de vulnerabilidades críticas abiertas en ambiente productivo	Semanal	0 (tolerancia controlada)
Cobertura de análisis SAST/DAST	Calidad	Aplicaciones con escaneo activo / Total de aplicaciones en	Mensual	$\geq 95\%$

		alcance		
Éxito de liberación segura	Calidad	Releases sin hallazgos críticos previos a producción / Total releases	Mensual	$\geq 90\%$
Disponibilidad de componentes críticos del servicio	Disponibilidad	Tiempo disponible / Tiempo total (SIEM, WAF, scanners)	Mensual	$\geq 98\%$
Cumplimiento de capacitación	Capacidad	Personal capacitado / Personal clave	Trimestral	$\geq 80\%$

9.8 Beneficios esperados

- Protección proactiva contra amenazas cibernéticas.
- Cumplimiento de normativas de seguridad y protección de datos.
- Reducción del riesgo de brechas de seguridad.
- Mejora en la confiabilidad y disponibilidad de las aplicaciones.
- Incremento en la confianza de usuarios y stakeholders.

9.9 Planeación de alto nivel

- Preparación: definición de alcance, catálogo de aplicaciones, criterios de severidad y modelo de operación.
- Implementación técnica: habilitación de SAST/DAST, integración CI/CD, configuración de WAF/SIEM y canal de tickets.
- Operación controlada: pilotos por aplicación, ajuste de reglas, reducción de falsos positivos y capacitación a equipos.
- Operación formal: métricas mensuales, auditorías periódicas, pentesting programado y mejora continua.

9.10 Dependencias con otros proyectos

¿Existe dependencia con otros proyectos?	NO	Describa con cuáles:	N/A
--	----	----------------------	-----

9.11 Personal involucrado

Perfil	Número	Tipo de Contratación
Arquitecto de seguridad	1	Tiempo Completo
Especialista en seguridad de aplicaciones	2	Tiempo Completo
Analista de vulnerabilidades	1	Tiempo Completo
Administrador de sistemas	1	Parcial

9.12 Justificación económica del proyecto de TI

9.12.1 Estudio de mercado

Se realizó un análisis comparativo de las principales soluciones de seguridad de aplicaciones disponibles en el mercado, considerando proveedores líderes como:

- Checkmarx - Solución SAST/DAST integrada.
- Veracode - Plataforma en la nube para análisis estático y dinámico
- SonarQube - Herramienta de inspección continua de calidad de código
- Fortify - Suite completa de seguridad de aplicaciones
- Snyk - Solución focalizada en vulnerabilidades de dependencias

El análisis consideró criterios de: capacidad de integración con el stack tecnológico existente, costo total de propiedad, facilidad de uso, y soporte técnico disponible localmente.

9.12.2 Costos de mantenimiento

- Licencias de software SAST/DAST: \$450,000 Anual
- Hardware dedicado para análisis: \$180,000 Un pago (año 1)
- Mantenimiento y actualizaciones: \$90,000 Anual
- Servicios de consultoría especializada: \$120,000 Anual

9.12.3 Costos de operación

- Capacitación y certificación del personal: \$60,000 Anual
- Consumibles y licencias adicionales: \$30,000 Anual
- Suscripción a feeds de inteligencia y amenazas: \$45,000 Anual

9.12.4 Procedimientos de adquisición

- Identificar los datos y sistemas importantes que la aplicación debe proteger.
- Analizar los posibles riesgos y vectores de ataque específicos de la aplicación.
- Definir las necesidades de seguridad para cada aplicación.

10. Cédula de Servicio (ITIL)

10.1 Información general del servicio

Nombre de la Empresa:		AppSec & NetGuard		
Departamento:		Seguridad de la Información		
Nombre del servicio	Seguridad de aplicaciones			
Tipo de servicio	Nuevo : (X)	Cambio: ()	Retiro: ()	Activo: ()
Listado de la(s) variante(s) o sub-servicio(s)	Auditoria de Vulnerabilidades: Escaneos, análisis técnicos y pruebas de penetración. Arquitectura de Red Segura: Implementación de WAF, Firewalls y segmentación.		Gestión de Parches de Seguridad: Abordar las debilidades de seguridad más graves identificadas en la lista pública Common Vulnerabilidades and Exposures (CVE).	
Descripción y alcance del servicio	Este El servicio proporciona una arquitectura de red robusta, creada para resguardar y administrar los bienes digitales de la organización a través de la aplicación de controles perimetrales avanzados. El propósito principal es garantizar la integridad de la infraestructura tecnológica, estableciendo barreras defensivas que protejan los datos críticos ante amenazas externas e internas. El servicio abarca el ciclo de vida de seguridad de forma exhaustiva, cubriendo desde la fase de diseño de la topología de red segura hasta la realización de pruebas de penetración previas a las fases productivas. Además, incluye la realización de auditorías periódicas a las aplicaciones web y móviles para detectar debilidades y Reducir los riesgos de manera proactiva.			
Objetivo del servicio		Asegurar la confidencialidad, la integridad y el acceso a los aplicativos de la organización, reduciendo el área de ataque a través de una arquitectura segura y la identificación anticipada de errores de seguridad.		
Usuarios a quienes se brinda el servicio		Departamento de Desarrollo (DevOps), Gerencia de TI, y Dueños de Aplicaciones de Negocio.		
Beneficios del servicio		• Reducción del riesgo de fugas de información. • Cumplimiento normativo (ISO 27001, GDPR). • Continuidad operativa ante ciberataques (DDoS).		
Demanda del servicio		Alta demanda durante los ciclos de liberación de software (sprints) y monitorización continua 24/7 para la infraestructura de red.		

10.2 Responsables del servicio (Matriz RACI)

Para la gestión de este servicio se han definido los siguientes roles asignados al personal disponible:

R = Responsable (ejecuta)

A = Aprobador (valida)

C = Consultado (experto)

I = Informado (notificado).

Actividad/ROL	Arquitecta Lider	Auditor Pentester	Ing. Redes y Soporte
Definición de Políticas de Seguridad.	R/A	C	I
Diseño de Arquitectura de Red Segura.	R	C	C
Modelado de Amenazas.	R	R	I
Evaluación de Riesgos de Terceros.	A	R	I
Aprobación de Pases a Producción.	A	C	I
Generación de Reportes Ejecutivos de SLA.	R	I	I
Configuración de Firewalls y WAF.	A	C	R
Afinamiento de Reglas WAF.	I	C	R
Gestión de Certificados Digitales.	I	I	R
Gestión de Identidades y Accesos.	I	I	R
Configuración de VPNs y Accesos Remotos.	C	C	R
Hardening (Endurecimiento) de Servidores.	A	I	R
Implementación de Parches de Seguridad Críticos.	I	I	R
Respaldo y Restauración de Configuraciones.	I	R	C
Ejecución de Auditorías Automáticas.	I	R	I
Revisión Manual de Código Fuente.	A	R	I
Pruebas de Penetración.	C	R	R
Monitorización de Logs y Alertas.	C	R	C

Análisis Forense y Post-Mortem de Incidentes.	A	R	C
Capacitación en Desarrollo Seguro a Programadores,	R	R	I

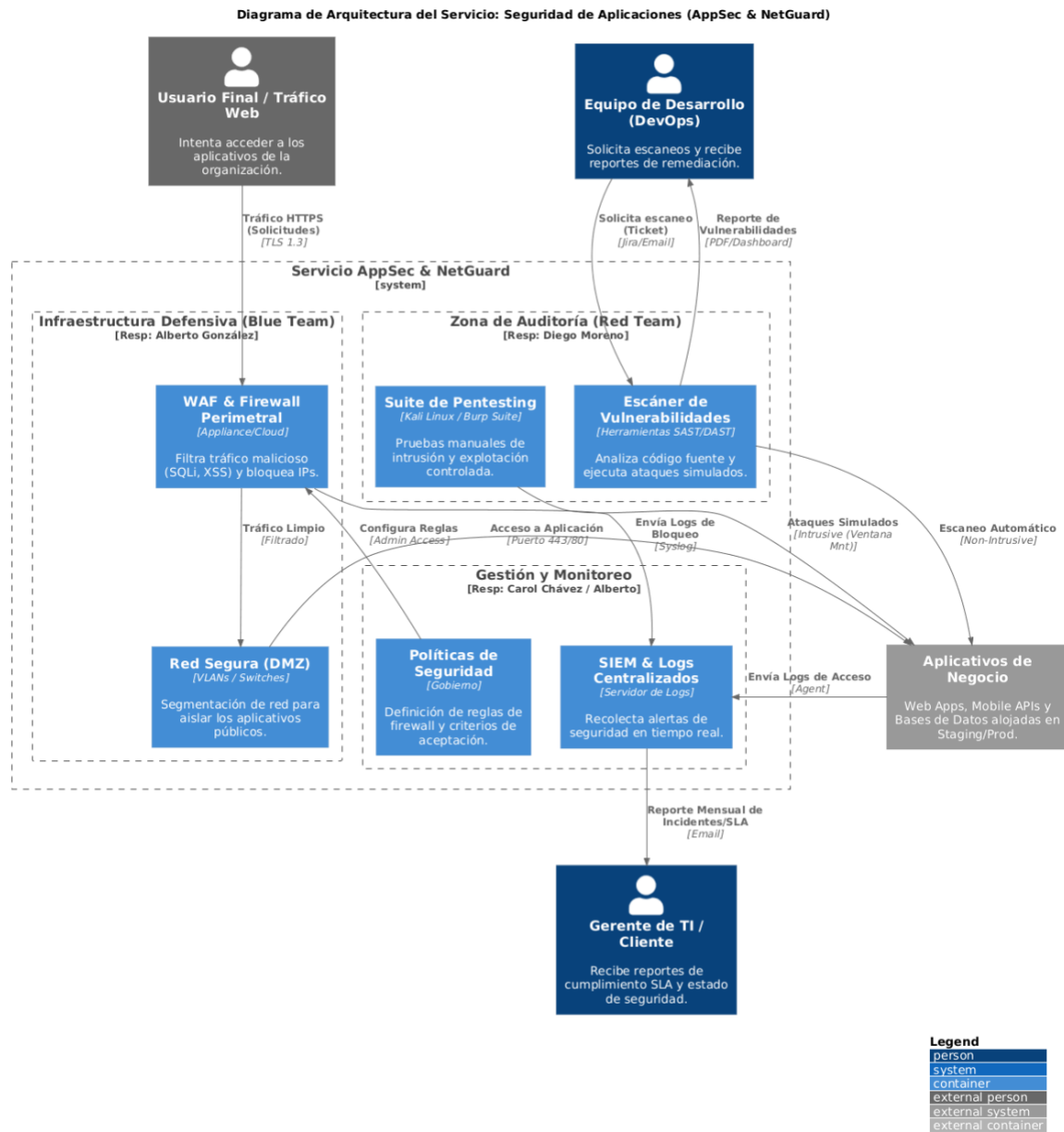
10.3 Roles y puntos de contacto

Rol	Nombre	Correo electrónico	Teléfono/ extensión	Horario de atención
Arquitecta Lider	Carol Monserrat Chávez Hernández	cchavez1900@alumno.ipn.mx	5566778888	7:00 a 15:00
Auditor Pentester	Diego Alejandro Moreno Martínez	dmoren2002@alumno.ipn.mx	5571986878	15:00 a 22:00
Ing. Redes y Soporte	Alfredo Bautista Ríos	abautista1700@alumno.ipn.mx	5510810077	7:00 a 15:00

10.4 Condiciones generales / requisitos para proporcionar el servicio

- **Permiso formal para realizar pruebas:** Es esencial tener un oficio firmado por la Dirección o el propietario del activo, que dé autorización explícita para realizar escaneos de vulnerabilidades y pruebas de penetración. Este documento tiene que liberar al equipo de seguridad de cualquier responsabilidad si el servicio se interrumpe debido a las pruebas de estrés acordadas.
- **Accesos privilegiados y capacidad de conexión:** El personal del servicio (Roles de Auditoría y Arquitectura) debe tener acceso a la red interna, ya sea a través de una VPN o directamente. Además, las credenciales administrativas (root/admin) deben estar habilitadas temporalmente en los entornos de QA o Staging para poder configurar inicialmente los dispositivos de seguridad (Firewalls/WAF).
- **Disponibilidad de entornos para pruebas:** Las pruebas de carga y las auditorías intrusivas se llevarán a cabo, preferiblemente, en entornos de preproducción (QA/Staging) que sean copias fieles de la producción. Si es necesario auditar el entorno de producción, esta debe hacerse durante las ventanas de mantenimiento aprobadas y bajo una supervisión rigurosa.
- **Política de respaldos:** Antes de cualquier prueba de penetración agresiva o intervención mayor, es obligación del propietario del aplicativo hacer un respaldo total de las bases de datos y configuraciones. Si no se cuenta con un punto de restauración validado, el servicio de seguridad no asume la responsabilidad por la pérdida de datos.
- **Ventanas para la conservación:** Para que la continuidad de las operaciones del negocio no se vea afectada, es necesario que el cliente establezca y cumpla con las ventanas de mantenimiento (horarios de baja transacción) para aplicar parches críticos y reiniciar los dispositivos de red.

10.5 Identificación de componentes de infraestructura



10.6 Niveles de servicio (SLA - acuerdos de servicios para los usuarios)

Tipo de nivel de servicio	Compromiso del nivel de servicio
Disponibilidad	Brindar el servicio las 24 horas del día, los 365 días del año. Incluye monitoreo continuo de las aplicaciones críticas y alerta temprana ante incidentes.
Soporte vía remota y presencial:	Atención remota en modalidad 24/7 y soporte presencial programado. Incluye resolución de incidencias, asistencia técnica, orientación en uso de la plataforma y acompañamiento en actividades operativas.
Confidencialidad	Protección de la información del usuario mediante controles de acceso, cifrado en tránsito y en reposo, y políticas de manejo seguro de datos.
Seguridad	Se asegura que solo personal autorizado puede acceder a la información generada durante el servicio. Aplicación continua de medidas de seguridad preventivas y reactivas, como análisis SAST/DAST, gestión de vulnerabilidades, revisión de configuraciones, y monitoreo ante posibles ataques. Incluye reportes mensuales del estado de seguridad y recomendaciones de mitigación.

10.7 Niveles de servicio (OLA-acuerdos de servicios respecto a elementos de configuración de infraestructura, aplicaciones, etc.)

Elementos de configuración	Tipo de nivel de servicio y compromiso del nivel de servicio	Métricas de los niveles de servicio
INFRAESTRUCTURA DE RED	Nivel 1: Básico Monitoreo estándar de reglas perimetrales. Actualización de firmas de ataques cada 48 horas.	Disponibilidad: 98.0% MTRS: <8horas Latencia agregada:<50ms

	Nivel 2: Intermedio Monitoreo activo de tráfico. Actualización de firmas cada 24 horas. Alta disponibilidad en modo Activo-Pasivo.	Disponibilidad: 98.0% MTRS: <4horas Latencia agregada:<20ms
	Nivel 3: Avanzado Monitoreo en tiempo real con IA. Actualización automática de firmas. Alta disponibilidad en modo Activo-Activo.	Disponibilidad: 99% MTRS: <1hora Latencia agregada: <5ms
SERVIDORES / MÁQUINAS VIRTUALES	Nivel 1: Básico Monitoreo estándar de CPU, RAM y disco. Parches de seguridad críticos cada 72h.	Disponibilidad 97% MTRS: <10 horas Latencia agregada: <80ms
	Nivel 2: Intermedio Monitoreo activo del estado de servicios. Automatización parcial de parches. Antivirus/EDR básico.	Disponibilidad: 98.5% MTRS: <6 horas Latencia agregada: <40 ms
PLATAFORMAS DE AUDITORIA	Nivel 1: Básico Escaneos programados semanalmente. Integración con repositorio de código.	Capacidad: Hasta 20 apps Tiempo de escaneo: 12hrs Retención de reportes: 6 meses
	Nivel 2: Intermedio Escaneos continuos (CI/CD Pipeline).	Capacidad: Ilimitada Tiempo de escaneo: <2hrs Retención de reportes:

	Dashboard de vulnerabilidades en tiempo real.	1 año
--	---	-------

11. Inventario de Activos

El inventario se presenta por proceso para asegurar control operativo y facilitar análisis de continuidad. Se considera como criticidad la contribución del activo a la postura de seguridad y a la operación del servicio.

Proceso	Activo	Tipo	Descripción	Criticidad
Evaluación de seguridad de aplicaciones	Plataformas SAST/DAST	Software	Análisis estático y dinámico integrado a CI/CD.	Alta
	Suite de pentesting (Red Team)	Software	Herramientas controladas para pruebas de penetración.	Media
	Entorno de staging en nube	Infraestructura	Ambiente de pruebas aislado previo a producción.	Alta
Gestión de vulnerabilidades y hardening	Plataforma de tickets (ITSM)	Software	Registro, asignación y seguimiento de hallazgos.	Alta
	Procedimientos de parcheo/hardening	Proceso	Guías de endurecimiento y ventanas de mantenimiento.	Alta
	Workstations del equipo	Endpoint	Equipos para análisis y soporte (Blue/Red/DevSecOps).	Media
Monitoreo y respuesta a incidentes	SIEM y logs centralizados	Servidor/Software	Correlación, alertas y retención forense.	Alta
	WAF/Firewall perimetral	Appliance	Mitigación y control de tráfico hacia apps.	Alta
	Microsoft 365 + Teams	Software	Canales de coordinación y comunicación durante incidentes.	Media

12. Matriz de Riesgos (ISO 27000) (Matriz CID, matriz de infraestructuras críticas)

Se evalúan riesgos considerando el impacto a Confidencialidad (C), Integridad (I) y Disponibilidad (D), así como la criticidad de la infraestructura que soporta el servicio. La valoración es cualitativa (Alta/Media/Baja) y permite priorizar controles.

Activo	C	I	D	Justificación (resumen)	Controles recomendados
Plataformas SAST/DAST	Media	Alta	Media	Definen hallazgos y calidad; caída afecta liberaciones.	Alta disponibilidad lógica, respaldos de configuración, control de acceso.
SIEM y logs centralizados	Alta	Alta	Alta	Datos sensibles y forenses; indisponibilidad afecta detección.	Retención cifrada, RBAC, redundancia y monitoreo.
WAF/Firewall perimetral	Media	Alta	Alta	Control de perímetro; falla expone aplicaciones.	HA/cluster, cambios controlados, backups de reglas.
Plataforma ITSM	Media	Media	Alta	Trazabilidad de remediación y SLA.	Backups diarios, roles, continuidad del proveedor.
Entorno de staging	Media	Media	Media	Ambiente de pruebas; posible exposición si se configura mal.	Segregación de redes, llaves rotadas, hardening.

12.1 Infraestructuras críticas

Infraestructura/s servicio	Criticidad	Dependencias	Impacto principal	Acciones de protección
SIEM y almacenamiento de logs	Crítica	Servidor, red, almacenamiento, credenciales	Detección y forense se degradan; riesgo de no cumplimiento.	Redundancia, cifrado, monitoreo, pruebas de restauración.
WAF/Firewall perimetral	Crítica	Energía, red, gestión de cambios	Aumento inmediato de exposición y ataques.	HA, backups, ventanas de cambio, revisión de reglas.
CI/CD y repositorios	Alta	Herramientas DevOps, credenciales	Controles no se ejecutan; liberaciones sin evaluación.	Integridad de pipelines, MFA, segregación y auditoría.
Service Desk / ITSM	Alta	Proveedor/infra	Se pierde control y trazabilidad de remediación.	Plan alternativo de registro, backups y exportaciones

				periódicas.
--	--	--	--	-------------

13. BIA Táctico

Los BIAs tácticos se enfocan en cada proceso operativo del servicio, identificando objetivos de recuperación y estrategias para mantener una operación segura ante interrupciones.

13.1 BIA Táctico 1: Evaluación de seguridad de aplicaciones

Identificación de vulnerabilidades antes de producción mediante escaneo automatizado (SAST/DAST), revisión de código y pruebas controladas.

Elemento	Detalle
Actividad crítica	Evaluación de seguridad de aplicaciones
MTD (Máximo tiempo tolerable de interrupción)	5 días
RTO (Objetivo de tiempo de recuperación)	48 horas
RPO (Objetivo de punto de recuperación)	24 horas
Dependencias clave	Herramientas SAST/DAST, CI/CD, repositorios, entornos de prueba, credenciales y personal Red Team/DevSecOps.
Impactos principales	Riesgo de liberación con vulnerabilidades críticas; aumento de retrabajo; incremento de incidentes; afectación reputacional.
Estrategias de continuidad	Ejecución manual de escaneos, priorización por criticidad, perfiles preconfigurados y operación por lotes.

13.2 BIA Táctico 2: Gestión de vulnerabilidades y hardening

Conversión de hallazgos en acciones: registro en ITSM, asignación, seguimiento, validación y cierre, incluyendo parches y hardening.

Elemento	Detalle
Actividad crítica	Gestión de vulnerabilidades y hardening
MTD (Máximo tiempo tolerable de interrupción)	3 días
RTO (Objetivo de tiempo de recuperación)	24 horas
RPO (Objetivo de punto de recuperación)	24 horas
Dependencias clave	ITSM, responsables de aplicaciones, administración de servidores/red, ventanas de cambio y respaldos de configuración.
Impactos principales	Acumulación de vulnerabilidades; incumplimiento de SLA; incremento de superficie de ataque; posibles impactos regulatorios.
Estrategias de continuidad	Registro alternativo con plantillas, exportaciones periódicas, priorización por severidad y control de excepciones.

13.3 BIA Táctico 3: Monitoreo y respuesta a incidentes

Detección, análisis y contención mediante SIEM, WAF y monitoreo, con escalamiento y análisis forense cuando aplique.

Elemento	Detalle
Actividad crítica	Monitoreo y respuesta a incidentes
MTD (Máximo tiempo tolerable de interrupción)	24 horas
RTO (Objetivo de tiempo de recuperación)	2 horas
RPO (Objetivo de punto de recuperación)	1 hora
Dependencias clave	SIEM, WAF/Firewall, conectividad, acceso a logs, canales de comunicación y guardias de operación.
Impactos principales	Mayor tiempo de detección; crecimiento del impacto del ataque; pérdida de evidencias; degradación de servicios críticos.
Estrategias de continuidad	Redundancia en componentes, alertamiento alternativo, runbooks de contención y simulacros periódicos.

14. BIA Operacional

El BIA operacional consolida el impacto a nivel servicio, integrando procesos, activos y dependencias compartidas para establecer prioridades de recuperación y criterios de activación.

Elemento	Detalle
Servicio	Servicio Integral de Seguridad de Aplicaciones
Actividades críticas	Monitoreo y contención; gestión de vulnerabilidades; evaluación previa a liberación; comunicación y reporte.
Activos críticos	SIEM/logs, WAF/Firewall, ITSM, SAST/DAST, CI/CD y repositorios.
MTD (servicio)	24 horas (degradación significativa de postura de seguridad)
RTO global (prioritario)	2 horas para monitoreo/alertas; 24-48 horas para evaluación y gestión de tickets
RPO global	1-24 horas según componente (logs y tickets priorizados)
Dependencias	Energía, red, accesos (MFA), cuentas de nube, proveedores de licencias, equipos de desarrollo/operación.
Escenarios principales	Caída de SIEM; indisponibilidad de WAF; falla en CI/CD; indisponibilidad ITSM; pérdida de credenciales; ataque a infraestructura.

15. Plan de Continuidad

15.1 Activación y gobernanza

Elemento	Definición
Criterios de activación	Indisponibilidad de componentes críticos > RTO; incidente

	severo con riesgo de propagación; pérdida de integridad de logs.
Comité de continuidad (roles)	Arquitecta Líder (coordina), Auditor Pentester (análisis técnico), Ing. Redes/Soporte (contención), Service Desk (registro y comunicación).
Canales de comunicación	Teams/correo; canal alternativo (teléfono) para contingencia; bitácora central de decisiones.

15.2 Estrategias por escenario

Escenario	Acción inmediata	Estrategia de continuidad	Recuperación
Caída de SIEM/logs	Habilitar alertas directas desde WAF/Firewalls y sistemas críticos.	Retención local temporal; exportación manual; priorizar eventos críticos.	Restaurar SIEM desde respaldo y validar integridad de logs.
Falla de WAF/Firewall	Aplicar reglas mínimas en equipo alternativo o modo bypass controlado.	Bloqueos en red (ACL) y hardening temporal; monitoreo reforzado.	Restaurar configuración respaldada y validar reglas.
Indisponibilidad de ITSM	Registro temporal en plantilla controlada.	Asignación por correo/Teams; seguimiento manual con folio temporal.	Importación de registros a ITSM y cierre formal.
Falla en CI/CD o herramientas SAST/DAST	Congelar liberaciones de alto riesgo; ejecutar análisis manual.	Escaneo por lotes; revisión de código focalizada; priorización por criticidad.	Restablecer herramientas y reactivar controles en pipeline.

15.3 Respaldo, restauración y pruebas

Se deben mantener respaldos de configuraciones (WAF/Firewall), plantillas de reglas, catálogos de aplicaciones, exportaciones periódicas de tickets y políticas de escaneo. Las pruebas de continuidad se recomiendan de forma semestral mediante simulacros, verificando tiempos de recuperación, integridad de evidencias y canales de comunicación.

16. Anexos

16.1 Glosario

Concepto	Descripción
SAST (Static Application Security Testing)	Análisis de código fuente para identificar vulnerabilidades sin ejecutar la aplicación.
DAST (Dynamic Application Security Testing)	Pruebas de seguridad realizadas en tiempo de ejecución para detectar vulnerabilidades.
DevSecOps	Integración de prácticas de seguridad en el ciclo

	de vida de desarrollo de software.
XSS (Cross-Site Scripting)	Vulnerabilidad de seguridad en la cual un atacante inserta scripts maliciosos en aplicaciones web, que son ejecutados por los navegadores de los usuarios
Inyección SQL	Técnica de ataque que permite a un atacante ejecutar comandos SQL maliciosos en una base de datos, comprometiendo la integridad y confidencialidad de los datos.
API (Interfaz de Programación de Aplicaciones)	Conjunto de definiciones y protocolos que permiten la integración entre diferentes sistemas o aplicaciones. Las APIs mal implementadas pueden ser vulnerables a ataques.
Man in the Middle (MitM)	Tipo de ataque en el que un atacante intercepta y manipula la comunicación entre dos partes sin que ellas lo detecten, con el fin de robar o modificar la información transmitida.
CID (Confidencialidad, Integridad y Disponibilidad)	Triada que clasifica el impacto de un incidente: exposición de datos (C), alteración no autorizada (I) y pérdida de acceso (D).
BIA (Business Impact Analysis)	Análisis que identifica impactos al negocio por interrupciones y define prioridades y objetivos de recuperación.
MTD (Maximum Tolerable Downtime)	Tiempo máximo tolerable de interrupción antes de que el impacto sea inaceptable para el negocio.
RTO (Recovery Time Objective)	Tiempo objetivo para restaurar un proceso/servicio después de una interrupción.
RPO (Recovery Point Objective)	Antigüedad máxima tolerable de la información al recuperar (pérdida de datos permitida).
MTTR (Mean Time To Restore/Recover)	Tiempo promedio para restaurar un servicio tras una falla o incidente.
SLA (Service Level Agreement)	Compromiso medible de nivel de servicio acordado con el usuario/cliente del servicio.
OLA (Operational Level Agreement)	Acuerdo interno entre áreas/proveedores internos que soportan el cumplimiento de un SLA.
SCA (Software Composition Analysis)	Análisis de dependencias y librerías de terceros para identificar vulnerabilidades y licencias de

	riesgo.
CVE (Common Vulnerabilities and Exposures)	Catalogo publico de identificadores para vulnerabilidades conocidas.
CVSS	Sistema estandar para puntuar severidad de vulnerabilidades (impacto y explotabilidad) en una escala numerica.
OWASP Top 10	Lista de riesgos mas comunes en aplicaciones web; se usa como referencia para priorizar controles y pruebas.
Hardening	Endurecimiento de configuracion para reducir superficie de ataque (servicios minimos, permisos, cifrado, politicas).
Gestion de parches (Patch management)	Proceso para evaluar, aprobar, desplegar y verificar parches de seguridad y actualizaciones.
WAF (Web Application Firewall)	Control perimetral que inspecciona trafico HTTP(S) y bloquea patrones de ataque hacia aplicaciones web.
Firewall	Control de red que filtra trafico segun reglas (puertos, protocolos, IPs) para limitar accesos no autorizados.
SIEM	Plataforma que centraliza logs, correlaciona eventos y genera alertas para deteccion y respuesta a incidentes.
IDS/IPS	Sistemas de deteccion/prevencion de intrusiones que identifican trafico malicioso y pueden bloquearlo.
EDR	Solucion de deteccion y respuesta en endpoints (equipos) para identificar comportamiento malicioso y contenerlo.
RBAC	Control de acceso basado en roles; asigna permisos segun funciones para aplicar minimo privilegio.
MFA	Autenticacion multifactor; reduce el riesgo de compromiso de cuentas aun si se filtra una contrasena.
Entorno de staging	Ambiente de reproduccion que replica

	condiciones de produccion para validar cambios y pruebas de seguridad.
Runbook	Guia operativa paso a paso para ejecutar tareas repetibles (p. ej., contencion, restauracion, despliegue).
Playbook de respuesta a incidentes	Procedimiento para un tipo de incidente (p. ej., XSS, credenciales comprometidas), con roles, decisiones y acciones.
DDoS	Ataque de denegacion de servicio distribuido que satura recursos para degradar o tumbar aplicaciones.
Retencion de logs	Politica de almacenamiento y preservacion de registros para auditoria y analisis forense.